

HealthData Cloud Cybersecurity Risk Assessment

NIST-aligned assessment of business-critical assets, key risk scenarios, and treatment priorities

Client / Entity	HealthData Cloud (fictional)
Prepared By	GRC Analyst Portfolio
Framework Basis	NIST SP 800-30 concepts
Document Type	Risk Assessment Report
Version	1.0

Prepared by Gustavo do Carmo Lemes as part of a hands-on GRC portfolio project. Assessment methodology follows NIST SP 800-30 risk analysis concepts, adapted for a fictional healthcare SaaS scenario.

1. Executive Summary

This assessment evaluates cybersecurity risk exposure for HealthData Cloud, a fictional software-as-a-service provider that stores personally identifiable information and protected health information. The assessment identified three primary risk themes: credential-based attacks, inadequate logging and detection coverage, and dependence on third-party services without mature resilience requirements.

Based on inherent risk scoring, phishing-enabled credential theft, unauthorized database access, and ransomware present the highest current exposure. Recommended priorities are to implement multi-factor authentication, formalize security monitoring and incident logging, strengthen backup resilience, and expand third-party due diligence for critical vendors.

2. Assessment Scope and Methodology

- Assessment scope includes the production application, customer database, cloud identity platform, corporate email, employee endpoints, and critical third-party dependencies.
- Methodology aligns with core concepts from NIST SP 800-30 and common enterprise risk management practice.
- Each risk was evaluated using a 1-5 scale for likelihood and business impact. Inherent risk score equals Likelihood x Impact; residual risk score reflects the estimated risk after current controls.

3. Critical Asset Inventory

Asset	Business Function	Data Sensitivity	Primary Owner
Customer Database	Stores patient and customer records	High	Head of Engineering
Production Web Application	Delivers core SaaS platform	High	Application Engineering Manager
Cloud Identity Platform	Provides authentication and privileged access	High	IT Security Lead
Corporate Email	Internal and external business communications	Medium	IT Operations Manager
Employee Endpoints	Operational workforce productivity and access	Medium	IT Operations Manager

4. Key Threats and Vulnerabilities

Threat Scenario	Key Vulnerability	Current Condition
Phishing and credential theft	MFA not consistently enforced for all users	High probability of account compromise from user-targeted attacks
Ransomware through endpoint infection	Inconsistent endpoint control coverage and backup recovery testing	Potential interruption to operations and customer support functions
Unauthorized database access	Privileged access reviews informal and logging coverage limited	Delayed detection of misuse or anomalous access
Third-party service outage	Vendor resilience criteria not consistently assessed before onboarding	Operational dependence without documented recovery expectations

5. Top Risk Summary

Risk ID	Risk Statement	Likelihood	Impact	Inherent Risk	Target Treatment
R-01	Phishing attack leads to compromise of a cloud identity account	5	4	20 - Critical	Implement MFA and phishing-resistant awareness training
R-02	Unauthorized access to customer database results in data exposure	4	5	20 - Critical	Strengthen privileged access, logging, and quarterly reviews
R-03	Ransomware infection affects employee endpoints and shared services	4	4	16 - High	Improve endpoint controls, segmentation, and tested backups
R-04	Security monitoring gaps delay incident detection and escalation	3	4	12 - High	Centralize logs and define alerting use cases

6. Recommended 90-Day Action Plan

1. Enforce multi-factor authentication for email, VPN, privileged access, and administrator accounts.
2. Implement centralized logging for identity, endpoint, cloud, and application events; define severity thresholds and alert ownership.
3. Conduct an access review for privileged roles and database administrators; revoke or justify excessive access.
4. Test backup restoration for one customer-critical workload and document recovery time assumptions.
5. Adopt a critical-vendor questionnaire and require continuity, security, and incident-notification commitments.